ملاحظات الدرس — لك

نمذجة التهديدات لتطبيق ذكاء اصطناعي

أمن الذكاء الاصطناعي، الجامعة، الدرس ١

المدة
٢٠ دقيقة

المواد
ورق وأقلام، أو سبّورة بيضاء، تطبيق ذكاء اصطناعي تستخدمه أو تبنيه (تنظر إليه بصفتك مستخدمًا فقط)، أسئلة STRIDE الستة (في الشرائح)

أهداف التعلّم

- ترسم مسارات بيانات تطبيق ذكاء اصطناعي وحدود الثقة فيه.
- تجد التهديدات عند كل حدّ بأسئلة STRIDE، وترتّبها.
- تقلّص نطاق الضرر بالتصميم.

النشاط: نموذج تهديدات في عشرين دقيقة

١. الرسم (٦ دقائق): على صفحة واحدة، ارسم كل أجزاء التطبيق الذي اخترته (المستخدم، والتطبيق، والنموذج، وأدواته، ومستنداته، والمحتوى الخارجي الذي يقرؤه)، وسهمًا لكل مسار بيانات بينها.

٢. الحدود (٤ دقائق): ضع دائرة حول كل موضع تدخل منه بيانات لا تتحكّم فيها: الرسائل، والملفات المرفوعة، وصفحات الويب، ونتائج الأدوات. وتذكّر أن النموذج ليس حدًّا: فكل ما في سياقه قد يوجّهه.

٣. STRIDE (٦ دقائق): لكل حرف، اكتب تهديدًا واقعيًا واحدًا عند حدودك، وأعطه درجة الاحتمال × الأثر، من ١ إلى ٣ لكلٍّ منهما. وعلّم كل مسار من نص غير موثوق إلى جزء يتصرّف.

٤. الإصلاح (٤ دقائق): اختر تغيير التصميم الوحيد الذي يقلّص نطاق الضرر أكثر من غيره (إزالة أداة، أو القراءة فقط، أو الموافقة في الكود)، وقل كيف ستختبره.

استخدم تطبيقًا تبنيه، أو تصميمًا من خيالك. ولا تفحص نظامًا حيًّا لغيرك أبدًا.

للنقاش

- لماذا لا يُعدّ النموذج حدّ ثقة؟
- أيّ حرف من STRIDE كان إيجاد تهديد له الأصعب؟
- ما الذي يستطيع تطبيقك فعله ولا تحتاج إليه مهمته؟

تحقّق من نفسك

- سمِّ مسارًا واحدًا من نص غير موثوق إلى فعل في تطبيقك، والتغيير الذي يقطعه.

جرّبها هذا الأسبوع

مع زميلين، ارسموا مسارات البيانات لتطبيق ذكاء اصطناعي تستخدمونه في دراستكم، وضعوا دائرة حول كل حدّ ثقة، واطرحوا أسئلة STRIDE الستة، واتفقوا على التغيير الوحيد الذي يقلّص نطاق ضرره أكثر من غيره.

ورقة عمل

نمذجة التهديدات لتطبيق ذكاء اصطناعي

أمن الذكاء الاصطناعي، الجامعة، الدرس ١

الاسم ____ الفصل ____ التاريخ ____

١ لا يحتاج مساعد المقرر إلا إلى الإجابة عن الأسئلة من الملازم. أيّ تغيير يقلّص نطاق الضرر أكثر من غيره؟

○ تحذير في تعليمات النظام ○ إزالة أداة البريد الإلكتروني ○ نموذج أكبر وأذكى

٢ صِل كل تهديد من STRIDE بما قد يبدو عليه في مساعد المقرر.

الانتحال	• • • •	يكشف درجات طالب آخر
العبث	• • • •	رسالة تدّعي أنها من المحاضر
كشف المعلومات	• • • •	صفحة ويب تجعله يرسل بريدًا
رفع الصلاحيات	• • • •	شخص يعدّل الملازم التي يقرؤها

٣ يسرد نموذج التهديدات لمساعد المقرر مسارات بياناته. أكمل at_risk(flows, untrusted, acts): تتبّع المسارات خطوة خطوة من الأجزاء غير الموثوقة، وأعِد الأجزاء الفاعلة التي تبلغها مرتّبة. والبداية لا تنظر إلا إلى خطوة واحدة، فيفوتها المسار من web إلى model ثم إلى email.

```
FLOWS = [("model", "email"),
         ("web", "model"),
         ("student", "model"),
         ("model", "search")]

def at_risk(flows, untrusted, acts):
    reach = set(untrusted)
    for a, b in flows:
        if a in untrusted:
            reach.add(b)
    found = [c for c in acts if c in reach]
    return sorted(found)

for c in at_risk(FLOWS, {"web"}, {"email"}):
    print("at risk:", c)
```

اكتب برنامجك:

٤ يشغّل مساعد المقرر استدعاءات أدواته بهذا الكود. إلى جانب غياب خطوة الموافقة، أيّ تهديد من STRIDE يتركه مفتوحًا؟

```
def run_tool(call):
    if call["tool"] == "email":
        send(call["to"], call["body"])
    return "done"
```

◯ الإنكار: لا شيء يسجّل من أرسل ماذا ◯ العبث: إنه يعدّل ملازم المقرر التي يقرؤها

◯ تعطيل الخدمة: إنه يعيد إرسال كل بريد فاشل بلا نهاية

٥ رتّب خطوات نمذجة التهديدات.

☐ رتّب التهديدات بحسب الاحتمال × الأثر

☐ ارسم مسارات البيانات

☐ أعطِ أعلاها إجراءً وقائيًا واختبارًا

☐ اطرح أسئلة STRIDE عند كلٍّ منها

☐ حدّد حدود الثقة

✎ فكّر في تطبيق ذكاء اصطناعي تستخدمه في دراستك. من أين يدخله نص غير موثوق، وما أسوأ ما قد يُدفع إلى فعله؟

تحقّق من إجاباتك

نمذجة التهديدات لتطبيق ذكاء اصطناعي

أمن الذكاء الاصطناعي، الجامعة، الدرس ١

١ **إزالة أداة البريد الإلكتروني**

من دون أداة تتصرّف، أقصى ما تستطيعه صفحة مُتلاعَب بها أن تجعل المساعد يقول شيئًا خاطئًا.

٢ **الانتحال — رسالة تدّعي أنها من المحاضر**

العبث — شخص يعدّل الملازم التي يقرؤها

كشف المعلومات — يكشف درجات طالب آخر

رفع الصلاحيات — صفحة ويب تجعله يرسل بريدًا

يطرح كل حرف من STRIDE سؤالًا مختلفًا عند الحد: من هو حقًا، وهل يمكن تغيير البيانات، وما الذي قد يتسرّب، وأي قدرات قد يكتسبها نص خارجي.

٣

```
FLOWS = [("model", "email"),
         ("web", "model"),
         ("student", "model"),
         ("model", "search")]

def at_risk(flows, untrusted, acts):
    reach = set(untrusted)
    for _ in flows:
        for a, b in flows:
            if a in reach:
                reach.add(b)
    found = [c for c in acts if c in reach]
    return sorted(found)

for c in at_risk(FLOWS, {"web"}, {"email"}):
    print("at risk:", c)
```

يبلغ النص غير الموثوق النموذج، ويبلغ النموذج أداة البريد: خطوتان.

٤ **الإنكار: لا شيء يسجّل من أرسل ماذا**

يخرج كل بريد ولا يُكتب شيء: فإن جعلته صفحة مُتلاعَب بها يرسل شيئًا، فلن يستطيع أحد تتبّع متى أو لمن أو لماذا.

٥ **من الأعلى إلى الأسفل: ٤، ١، ٥، ٣، ٢**

لا تستطيع تحديد الحدود قبل رسم المسارات، ولا إيجاد التهديدات قبل الحدود.